

Übungsblatt 7
 Vorlesung “Cybersicherheit”
 Sommersemester 2025
 Praktische Übung Hashing Use-Cases

Hashing of Passwords

Hashing hat eine immense praktische Bedeutung für heutige Web-Apps, die oftmals zusätzliche Dienstleistungen und Funktionen nach dem *Login* bereitstellen. Dies kann zB. eine Zeitung sein, die Zeitungsartikel nur Nutzern mit einem Zeitungsabo bereitstellen. Oder aber auch Beispiele wie Online-Banking, Foren oder digitale Lehre. Die Universität Duisburg-Essen stellt mit der *Moodle* Plattform, eine Möglichkeit sich in Diskussionsforen aktiv mit anderen Studierenden zum Thema der Vorlesung auszutauschen. Es können aber auch über *Moodle* bewertete Abgaben vorgenommen werden. Ein *Login* erfordert die Eingabe eines Benutzernamen und Passworts.

Übung 1.

Rainbow-Tables sind ein Time-Storage Tradeoff. Rainbow-Tables sind besonders am Anfang der 2000er Jahre aufgrund von *unsalted*, *single-hashed* Passwörtern sehr beliebt gewesen. Eine Rainbow-Table lohnt sich besonders, wenn die Berechnungszeit der Hashes im Vergleich zu den Speicherkosten sehr hoch ist.

- Es gibt insgesamt 77 *printable non-control* ASCII Zeichen, welche für Passwörter verwendet werden können. Geben Sie die Anzahl an möglichen Passwörtern wenn die Passwortlängen auf: 4,5,6,7,8 Zeichen begrenzt wird.
- Nehmen wir an in einer Datenbank-Tabelle werden zwei Spalten als *char(10)* für das Passwort und *binary(16)* für den dazugehörigen Hash angelegt. Eine Zeile verbraucht folglich 26 B an Daten. Wie groß ist eine Rainbow-Tabelle für die zugelassenen Passwortlängen aus Teilaufgabe a).
- Ein moderner 4-Kerne Prozessor kommt bei einem modernen Hash-Verfahren wie **SHA-256** auf eine Geschwindigkeit von 200 000 Hashes/s. Berechnen Sie die Zeit, die der Prozessor braucht um eine Rainbow-Tabelle mit den Passwortlängen aus Teilaufgabe a) zu erstellen.

Hinweis: Sie können Ihre Berechnungen in Tabelle 1 eintragen.

max. Passwortlänge	Anzahl Passwortkombinationen	Disk-Größe Table	Rainbow-	CPU-Zeit
4				
5				
6				
7				
8				

Tabelle 1: Tabelle zur Aufgabe 1

Lösung 1.

a) Anzahl Passwortkombinationen

$$77^4 = 35\,253\,041$$

$$77^5 = 2\,706\,784\,157$$

$$77^6 = 208\,422\,380\,089$$

$$77^7 = 16\,048\,523\,266\,853$$

$$77^8 = 1\,235\,736\,291\,547\,681$$

b) Disk-Größe

$$77^4 * 26 \text{ Byte} \approx 913 \text{ MB}$$

$$77^5 * 26 \text{ Byte} \approx 70 \text{ GB}$$

$$77^6 * 26 \text{ Byte} \approx 5,4 \text{ TB}$$

$$77^7 * 26 \text{ Byte} \approx 417 \text{ TB}$$

$$77^8 * 26 \text{ Byte} \approx 32 \text{ PB}$$

c) CPU-Zeit

$$77^4 \div 200000 \text{ Hashes/s} \approx 3 \text{ Minuten}$$

$$77^5 \div 200000 \text{ Hashes/s} \approx 3,75 \text{ Stunden}$$

$$77^6 \div 200000 \text{ Hashes/s} \approx 12 \text{ Tage}$$

$$77^7 \div 200000 \text{ Hashes/s} \approx 2,5 \text{ Jahre}$$

$$77^8 \div 200000 \text{ Hashes/s} \approx 195 \text{ Jahre}$$

max. Passwortlänge	Anzahl Passwortkombinationen	Disk-Größe Rainbow-Table	CPU-Zeit
4	35253041	913 MB	3 Minuten
5	2706784157	70 GB	3,75 Stunden
6	208422380089	5,4 TB	12 Tage
7	16048523266853	417 TB	2,5 Jahre
8	1235736291547681	32 PB	195 Jahre

Kryptowährungen

Übung 2.

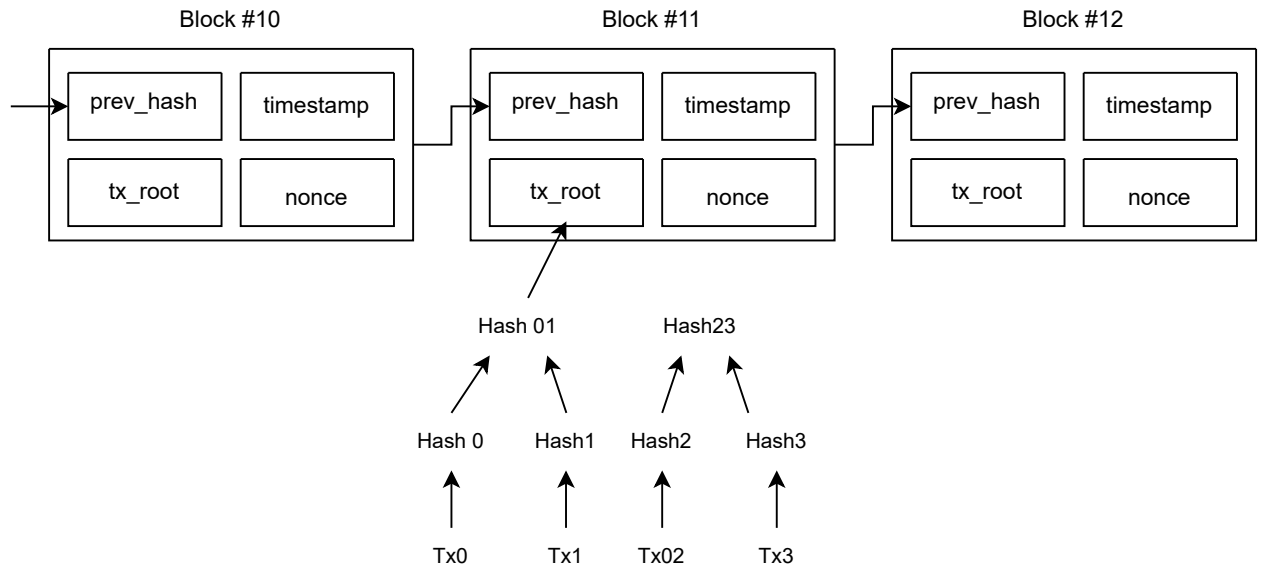
Bitcoin und Blockchains in der Theorie

- Beschreiben Sie den grundlegenden Aufbau einer Blockchain und ihren Zweck.
- Beschreiben Sie das Problem der Byzantinischen Generäle im Kontext von Bitcoin. Welche Lösungsansätze gibt es hier?
- Beschreiben Sie das *Proof of Work* Konzept. Wie kommt es bei Bitcoin zur Anwendung?
- Was ist ein *Merkle-Tree* und welche Rolle nimmt er in Bitcoin ein?

Lösung 2.

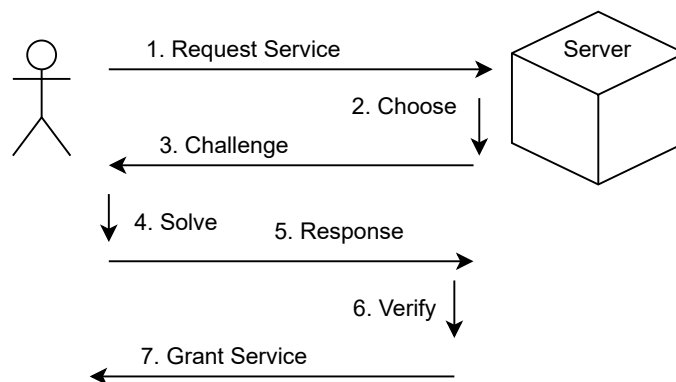
- Ein Block beinhaltet eine Liste aller Transaktionen und den Hash des zuvor geminten/gefundenen Blocks.
 - Blöcke werden durch Miner erstellt, Miner kombinieren alle Transaktionen in einem Block.
 - Miner kündigen einen neuen Block an, dieser muss aber durch das Netzwerk verifiziert und akzeptiert werden. Bei Akzeptanz wird eine Anzahl an Coins ausgezahlt.
 - Der Block erweitert bei Akzeptanz die Blockchain in jeder Kopie.
 - Der Block-Header hat unter anderem folgende Felder:
 - Hash des vorgegangenen Blocks.
 - Zeitpunkt wann der Block gemined wurde.

3. Merkle-root aller ink. Transaktionen.
4. Nonce.

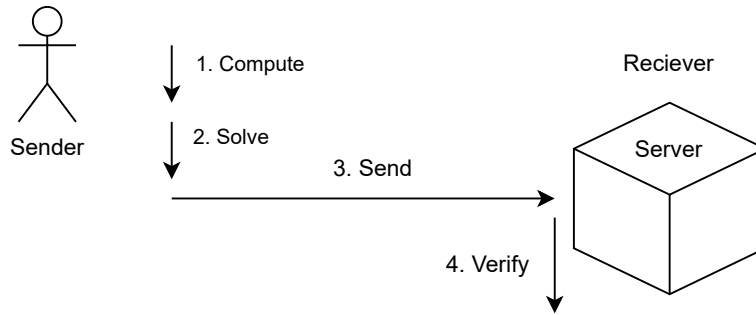


- b)
 - Eine öffentliche Blockchain mit dezentraler Struktur braucht eine Vertrauensbasis. Man kann aber niemanden im Netzwerk vertrauen.
 - Es muss Konsens unter den byzantinischen Generälen herrschen, Veräter unter den Generälen können den Erfolg gefährden.
⇒ Deshalb gehört die Vertrauensbasis in einer öffentlichen Blockchain zum "byzantinischen fault Problem".
 - Die Blockchain kann abweichen es bestehen gegebenenfalls mehrere Blockchain Nebenketten die längste wird anerkannt.
 - Damit jeder Knoten im Blockchain Netzwerk eine anerkannte Version der Blockchain hat, braucht es einen Konsensmechanismus.
 - Der Durchbruch der Blockchain hängt wesentlich mit der Erfindung des Proof-of-Work Konzepts zusammen. Der Proof-of-Work Mechanismus löst das Problem der byzantinischen Generäle in Bitcoin und anderen Blockchains. Ein alternativer Ansatz ist Proof-of-Stake.
- c)
 - Der Fragesteller muss etwas Arbeit vorableisten z.B ein Hash Puzzle lösen um einen Dienst in Anspruch zu nehmen.

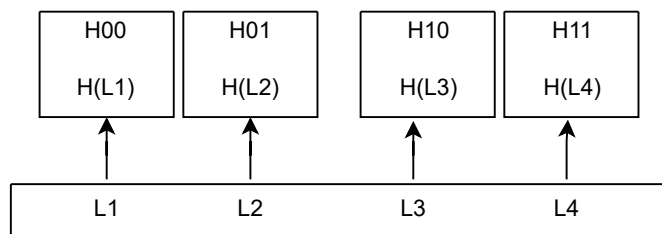
Challenge-Response:



Solution-Verification:



- Bei Bitcoin wird Proof-of-Work genutzt um einen Konsens im Netzwerk zu generieren.
- d)
- Ein Merkle-Tree enthält alle Knoten, welche selbst den Hash vom 'parent' enthalten.
 - Bei Bitcoin kann sind die Hashes: SHA-256



- Eine Manipulation kann durch den Merkle-Tree leicht detektiert werden.
- In Bitcoin werden die Transaktionen durch den Merkle-Tree vor Manipulation geschützt.

Übung 3.

CyberCoin ist eine Bitcoin-Variante und unterscheidet sich insbesondere durch eine geänderte Hashfunktion. Die Hashwerte sind immer ganzzahlig zwischen 0 und 99, Nachkommastellen werden abgeschnitten. Blöcke werden vom Netzwerk als gültig anerkannt, wenn ihr Hash größer oder gleich 90 ist. Die folgende Formel wird zur Berechnung des Hashes genutzt:

$$\begin{aligned}
 block_header &= (100000 \cdot prev_blockhash + 1000 \cdot time + 10 \cdot tx_root) \cdot (nonce + 1) \\
 block_hash &= \left(\frac{block_header}{773} + 4312 \right) \bmod 100
 \end{aligned}$$

- a) Vervollständige die Tabelle, die zwei aufeinanderfolgende, gültige Blöcken auflistet.

<i>prev_blockhash</i>	<i>time</i>	<i>tx_root</i>	<i>nonce</i>	<i>blockhash</i>
93	22	31		
	38	19		

- b) Das *Minen* eines neuen CyberCoin-Blockes ist auch mit einer Belohnung von 10 CyberCoins verbunden. Um die Inflation zu begrenzen wird dieser Finderlohn allerdings alle 730 Blöcke halbiert. Bestimmen Sie die maximale Anzahl an CyberCoins.

Lösung 3.

- a) Zufällige Nonce als 2 und im nächsten Schritt als 3 gewählt.

<i>prev_blockhash</i>	<i>time</i>	<i>tx_root</i>	<i>nonce</i>	<i>blockhash</i>
93	22	31	2	91
91	38	19	3	98

b) Intuition:

Coins = $730 * 10 + 730 * 5 + 730 * 2,5 \dots$

Da sich die Belohnungen alle 730 Blöcke halbiert kann hier die *geometrische Summenformel* zur Berechnung genutzt werden:

$$\sum_{k=0}^n q^k = \frac{1 - q^{n+1}}{1 - q}$$

Wobei man $q = 0,5$ für die Halbierung wählt.

$$\frac{730 * 10}{1 - 0,5} = \frac{7300}{0,5} = 14600$$

Bonus: Hash Cracking for the Hackers among us

Übung 4.

Passwörter werden als Hashes gespeichert, das gilt auch für passwortgeschützte Zip-Files. Im Zusatzmaterial der Übung im MoodleKurs (*ZusatzmaterialAufgabenblatt7.zip*) finden Sie eine Datei mit dem Namen `protected.zip` und eine Passwortliste `rockyou.txt`. Nutzen Sie die Tools `zip2john` aus der Software (John-the-Ripper) und das Tool `hashcat`. Um die Einrichtung dieser Tools zu vereinfachen nutzen Sie am besten eine virtuelle Maschine zB. VirtualBox und das Pentesting Linux Image: Kali. Sie finden eine englischsprachige Anleitung zur Installation von Kali Linux in VirtualBox unter:

<https://www.kali.org/docs/virtualization/install-virtualbox-guest-vm/>. In der VM sind die beiden notwendigen Tools `zip2john` und `hashcat` bereits vorinstalliert. **Hinweis:** Diese Bonusaufgabe richtet sich an Studierende, die sich in das Thema *Pentesting* einarbeiten wollen. Zudem sollten Sie für diese Aufgabe mit dem Umgang einer Kommandokonsole oder Shell vertraut sein. Eine gute Quelle um sich mit dem Betriebssystem Linux vertraut zu machen ist: SelfLinux (<https://www.selflinux.org/>) und für die Shell: <https://www.ernstlx.com/linux90bash.html>.

- a) Extrahieren Sie den Password-Hash aus der Datei `protected.zip` mit dem Tool `zip2john`.
- b) Nutzen Sie nun Hashcat und die Passwortliste `rockyou.txt` um eine sogenannte Dictionary-Attack (Ausprobieren von Passwörtern einer Liste) zu starten. Hashcat wird die Passwörter in Hashes umwandeln und nach einen passenden Passwort in der Liste suchen.